

Top Lessons For Open Source Pros From License Compliance Failures

Top Lessons For Open Source Pros From License Compliance Failures

Created on 2017-02-02 23:13

Published on 2017-02-07 20:12

In the past few years, several cases of non-compliance with open source licenses have made their way to the public eye. Increasingly, the legal disposition towards non-compliance has lessons to teach open source professionals. Here are my four top takeaways, gleaned from the years I've worked in open source.

1. Ensure Compliance Prior to Product Shipment/Service Launch

The most important lesson of non-compliance cases has been that the companies involved ultimately had to comply with the terms of the license(s) in question, and the costs of addressing the problem after the fact has categorically exceeded those of basic compliance. Therefore, it is really a smart idea to ensure compliance before a product ships or a service launches.

It is important to acknowledge that compliance is not just a legal department exercise. All facets of the company must be involved in ensuring proper compliance and contributing to correct open source consumption and, when necessary, redistribution.

This involvement includes establishing and maintaining consistent compliance policies and procedures as well as ensuring that the licenses of all the software components in use (proprietary, third-party, and open source) can co-exist before shipment or deployment.

To that effect, companies need to implement an end-to-end open source management infrastructure that will allow them to:

- Identify all open source used in products, presented in services, and/or used internally

- Perform architectural reviews to verify if and how open source license obligations are extending to proprietary and third-party software components
- Collect the applicable open source licenses for review by the legal department
- Develop open source use and distribution policies and procedures
- Mitigate risks through architecture design and engineering practices

2. Non-Compliance is Expensive

Most of the public cases related to non-compliance have involved GPL source code. Those disputes reached a settlement agreement that included one or more of these terms:

- Take necessary action to become compliant
- Appoint a Compliance Officer to monitor and ensure compliance
- Notify previous recipients of the product that the product contains open source software and inform them of their rights with respect to that software
- Publish licensing notice on company website
- Provide additional notices in product publications
- Make available the source code including any modifications applied to it (specific to the GPL/LGPL family of licenses)
- Cease binary distribution of the open source software in question until it has released complete corresponding source code or make it available to the specific clients affected by the non-compliance
- In some cases, pay an undisclosed amount of financial consideration to the plaintiffs

Furthermore, the companies whose compliance has been successfully challenged have incurred costs that included:

- Discovery and diligence costs in response to the compliance inquiry, where the company had to investigate the alleged inquiry and perform due diligence on the source code in question
- Outside and in-house legal costs
- Damage to brand, reputation, and credibility

In almost all cases, the failure to comply with open source license obligations has also resulted in public embarrassment, negative press, and damaged relations with the open source community.

3. Relationships Matter

For companies using open source software in their commercial products, it is recommended to develop and maintain a good relationship with the members of the open source communities that create and sustain the open source code they consume. The communities of open source projects expect companies to honor the licenses of the open source software they include in their products. Taking

steps in this direction, combined with an open and honest relationship, is very valuable.

4. Training is Important

Training is an essential building block in a compliance program, to ensure that employees have a good understanding of the policies governing the use of open source software. All personnel involved with software need to understand the company's policies and procedures. Companies often provide such education through formal and informal training sessions.

Learn more in the free "Compliance Basics for Developers" course from The Linux Foundation.

The following is adapted from "Open Source Compliance in the Enterprise" published by The Linux Foundation (free e-book download), a complete guide to creating compliance processes and policies for your organization.

Original post appeared on Linux.com.
